

# Enterprise Financial Payment Gateway

KTB Corporate Edition — Direct API Integration & Zero-Manual Reconciliation

## ARCHITECTURE

Multi-Tenant SaaS

## CORE BANKING

KTB Corporate (บจก.)

## SECURITY ENGINE

HS256 / AES-256

## RECONCILIATION

Real-time Auto Match

## 1 นิยามและคอนเซ็ปต์ของโปรเจกต์ (Project Definition & Core Concept)

**Project Concept:** ระบบ Payment Gateway ระดับ SaaS Enterprise ที่พัฒนาขึ้นโดยตรงกับ **Direct API** ของธนาคารกรุงไทย (KTB Corporate / บัญชี บจก.) เพื่อแก้ปัญหาความซับซ้อนของบัญชีบุคคลธรรมดา (ลดความเสี่ยงบัญชีถูกระงับหรือบัญชีปลิวจาก Transaction ใ้, ปลอดภัยทางการเงิน และขจัดเงื่อนไขการติดสแกนใบหน้า)

## ลำดับความสำคัญของกระบวนการตรวจสอบและยืนยันยอดเงิน (Reconciliation Hierarchy)

### 1 อันดับที่ 1: Direct Transfer Statement Matching

กลไกหลัก (PRIMARY MECHANISM)

- จับคู่จาก **Statement ธนาคารตรง:** ดึงข้อมูลเลขบัญชีผู้โอน (Sender Account) + ชื่อผู้โอน (Sender Name) + ยอดเงิน จับคู่แบบ Real-time
- ประสบการณ์ใช้งานสมบูรณ์แบบ: ลูกค้าโอนยอดตรงปกติ **ไม่ต้องมีเศษสตางค์** และ **ไม่ต้องแนบสลิป**

### 2 อันดับที่ 2: Dynamic QR Code / Floating Amount

กลไกสำรอง (FALLBACK MECHANISM)

- สุ่มเศษสตางค์อัจฉริยะ: สร้าง Unique Amount ด้วยเศษสตางค์ช่วง  $\pm 1.99$  บาท เช่น 500  $\rightarrow$  500.35 บาท
- PromptPay / Thai QR Payment:** ล็อกยอดและเวลาหมดอายุ Timeout (5-15 นาที) เพื่อจับคู่อัตโนมัติทันทีที่เงินเข้า

## ฟังก์ชันมาตรฐาน Payment Gateway สาทก (Enterprise Foundation)

STANDARD CAPABILITIES

🔑 **HS256** Digital Signature

🔒 **AES-256** Encrypted Webhook

🏦 **Verify** Bank Account Name

🏢 **Multi-Tenant** Data Isolation

📁 **Virtual Ledger** Partitioning

⚡ **100%** Idempotency Control

## 2 โครงสร้างหลักการทำงานสำคัญ (Core Principles & Workflows)

### 2.1 กระบวนการรับชำระเงิน (Inbound / Deposit Flow)

| ผู้ใช้งาน (Frontend)                                | ระบบ Merchant Backend                                                                              | Payment Gateway Engine                                                                                                                                                                                                       | KTB Corporate (บจก.)                                |
|-----------------------------------------------------|----------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| เลือกวิธีโอนเงินตรง<br>(ระบุเลขบัญชีต้นทาง)         | <b>1 ยืนยันชื่อ บช. ลูกค้า</b><br>POST /bank/verify/name                                           | <b>200 OK</b> (Account Name)                                                                                                                                                                                                 | -                                                   |
| -                                                   | <b>2 สร้าง Session รับเงิน</b><br>POST /deposit/create<br>(type: TRANSFER / QR)                    | <b>3 ล็อก Session</b> (Status: pending)<br><b>200 OK</b> (QR String / Pay Info)                                                                                                                                              | -                                                   |
| <b>4 แสดงข้อมูลบัญชี / QR</b><br>ลูกค้าทำการโอนเงิน | -                                                                                                  | -                                                                                                                                                                                                                            | เงินเข้าบัญชี บจก.<br>(Statement Update)            |
| -                                                   | -                                                                                                  | <b>5 อ่าน Inbound Statement</b><br><b>6 Matching Engine</b> ประมวลผล: <ul style="list-style-type: none"><li>• ตรวจสอบเลข บช. + ชื่อผู้โอน</li><li>• ตรวจสอบเลขสแตงค์ (กรณี QR)</li></ul> <b>7 ปรับสถานะ</b> <b>COMPLETED</b> | ส่ง Inbound Statement แบบ Real-time ผ่าน Direct API |
| -                                                   | <b>8 รับ Webhook Callback</b><br>POST callbackUrl<br>(AES-256 Hash + TxID)<br>ตอบกลับ: HTTP 200 OK | ยิง Encrypted Webhook ทันทีเมื่อ Matching สำเร็จ                                                                                                                                                                             | -                                                   |
| <b>9 ยอดเงินอัปเดตทันที</b><br><b>AUTO CREDIT</b>   | ปรับยอดเครดิตให้ลูกค้าในระบบ Merchant อัตโนมัติ                                                    | -                                                                                                                                                                                                                            | -                                                   |

#### Direct Transfer Matching (อันดับ 1)

PRIMARY ENGINE

ลูกค้าลงทะเบียนเลขบัญชีต้นทาง ระบบตรวจสอบความถูกต้องผ่าน POST /api/v1/client/bank/verify/bankAccountName  
เมื่อเงินเข้า Gateway จะดึง Statement จาก Direct API แล้วนำ **เลขที่บัญชีผู้โอน + ชื่อผู้โอน + ยอดเงิน** มาจับคู่กับรายการที่ตั้งไว้แบบ Real-time โดยไม่ต้องพึ่งพาเลขสแตงค์

#### Dynamic QR & Webhook Reconciliation

ZERO MANUAL  
100%

**Dynamic QR Code:** หากเลือกชำระผ่าน QR ระบบจะสุ่มเลขสแตงค์  $\pm 1.99$  บาท พร้อม Timeout 5-15 นาที สร้าง Unique Amount ล็อกยอดจับคู่อัตโนมัติ

**Webhook Reconciliation:** ยิง HTTP POST ไปยัง callbackUrl พร้อมส่ง Signature/Hash เซอร์ทิส ให้ Merchant ปรับเครดิตอัตโนมัติ 100%

## 2.2 กระบวนการจ่ายเงิน/โอนออก (Outbound / Direct Auto-Payout Flow)

**Plug-and-Play Integration:** ออกแบบมาเพื่อตัดขั้นตอน Manual Approval ออกทั้งหมด เพื่อให้ระบบหลังบ้านของ Merchant ส่งโอนเงินออกจากบัญชี บจก. ได้ทันทีในระดับวินาที (Direct Execution) ผ่าน Core Banking Direct API

| ระบบ Merchant Backend                                                                                                                                                               | Payment Gateway Engine                                                                                                                                 | KTB Corporate Direct API                                                              |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <div>1 สร้าง <b>Signature</b> (HS256 + iat ms)</div> <div>2 ยิงคำสั่งโอนออกทันที</div> <div>POST /api/v1/payout/create</div> <div>(amount, bankAccountNumber, bankName, name)</div> | <div>3 ตรวจสอบ <b>HS256 &amp; หัก Virtual Balance</b></div> <div>4 บันทึกคิว (Status: <b>PENDING</b>)</div> <div>200 OK (Status: pending, refid)</div> | -                                                                                     |
| -                                                                                                                                                                                   | <div>5 ส่งคำสั่งโอนเงินออกทันที</div> <div>Direct Outbound Fund Transfer</div> <div>(Status: <b>PROCESSING</b>)</div>                                  | รับคำสั่งจาก Gateway และตัดเงินออกจากบัญชี บจก. ทันที                                 |
| -                                                                                                                                                                                   | <div>7 อัปเดตสถานะเป็น <b>COMPLETED</b></div>                                                                                                          | <div>6 ธนาคารตัดเงินสำเร็จ</div> <div>ส่งคืน Transfer Success (Bank Ref / Slip)</div> |
| <div>8 รับ <b>Webhook Callback</b> ยืนยันผล</div> <div>POST callbackUrl</div> <div>(AES-256 Hash + Bank Ref)</div> <div>ตอบกลับ: HTTP 200 OK</div>                                  | ยิง Webhook แจ้งผลสำเร็จพร้อมแนบ Bank Reference กลับไปยัง Merchant ทันที                                                                               | -                                                                                     |

### สรุป 3 ขั้นตอนหลักของการประมวลผล Payout (Direct Execution Core)

#### STEP 1

##### Authentication & Validation

Merchant ส่ง Request พร้อม x-api-key และ signature (HS256 ผูกกับ timestamp ระดับ millisecond แบบ Single-Use) เพื่อยืนยันสิทธิ์ และตรวจสอบยอดเงินคงเหลือ

#### STEP 2

##### Direct Bank Dispatch

Gateway ตรวจสอบความถูกต้องและส่งคำสั่งโดยตรงเข้า KTB Corporate Core Banking ทันทีโดยไม่ต้องรอคอนมัติ ส่งโอนสำเร็จในระดับวินาที 24/7

#### STEP 3

##### Real-time Callback

เมื่อเงินถูกโอนเข้าบัญชีลูกค้าสำเร็จ ธนาคารตอบกลับสถานะ Gateway จะยิง Webhook แจ้ง completed พร้อมแนบ Slip Reference กลับไปยัง Merchant

### 3 สถาปัตยกรรมสำหรับขยายตัวสู่ระบบ SaaS Enterprise (Scale SaaS Considerations)

เพื่อให้แพลตฟอร์มสามารถขยายตัวรองรับลูกค้าหลายราย (Multi-Tenant) และมีเสถียรภาพสูง จำเป็นต้องวางโครงสร้างเพิ่มเติม 4 ด้านดังนี้:

#### 3.1 Dedicated Tenant Isolation

##### MULTI-TENANT

##### 1 บวก. ต่อ 1 Tenant (หรือเลือก Account Model):

- **Option A (Dual Account):** 1 Inbound (รับอย่างเดียว) + 1 Outbound (จ่ายอย่างเดียว) เพื่อรักษาความสะอาดของ Statement และลดความเสี่ยงการตรวจจับ
- **Option B (Single Account):** บัญชีทำทั้งรับและจ่าย สภาพคล่องไหลเวียนทันทีโดยไม่ต้องโยกเงินภายใน

**Virtual Ledger Isolation:** แยกฐานข้อมูลกระเป๋าเงิน (Tenant Balance), ประวัติธุรกรรม และค่าธรรมเนียมออกจากกันเด็ดขาด (Logical Data Partitioning)

#### 3.2 ความเสถียร & การจัดการทราฟฟิก

##### CONCURRENCY

- **Event-Driven Message Queue:** ใช้ Message Queue (เช่น Redis, RabbitMQ, Kafka) สำหรับคิวรับ Webhook และคำสั่ง Payout เพื่อรองรับคำขอพร้อมกันในช่วง Peak Load ได้อย่างราบรื่น ไม่เกิดปัญหา Request ค้างหรือเซิร์ฟเวอร์ล่ม
- **Idempotency Control:** ใช้ transactionId ที่ส่งมาจาก Merchant ล็อกใน Cache/Database เพื่อป้องกันการสั่งโอนเงินออกซ้ำ (Duplicate Payout) หรือการเติมเครดิตเบิ้ลจากการยิง Webhook ซ้ำ 100%

#### 3.3 ความปลอดภัย & ป้องกันการปลอมแปลง

##### SECURITY

- **Payload Hashing (AES-256):** ทุก Webhook Callback ต้องแนบค่า Hash ที่เข้ารหัสจาก transactionId ด้วย Key ลับ เพื่อให้ Merchant ตรวจสอบได้ว่าเป็นสัญญาณจริงจาก Gateway ไม่ใช่การยิงหลอก (Anti-Spoofing)
- **Single-Use Signature Policy:** ค่า Timestamp ใน Payload ต้องตรงกับ Claim iat ใน Signature และจำกัดอายุไม่เกิน 30-60 วินาที เพื่อป้องกัน Replay Attack

#### 3.4 การจัดการความเสี่ยงและสภาพคล่อง

##### RESILIENCE

- **Pre-funding & Minimum Balance Alert:** ระบบแจ้งเตือนเมื่อเงินคงเหลือในบัญชีฝั่งจ่าย (Outbound) ต่ำกว่า Buffer ที่กำหนด เพื่อป้องกันธุรกรรม Payout ติดสถานะล้มเหลว (Failed)
- **Circuit Breaker & Fallback Polling:** หาก Core Banking เกิดความล่าช้า ระบบจะมีโหมด Circuit Breaker หยุดรับคำขอชั่วคราว พร้อมมี API Polling (GET /api/v1/payout/:referenceId) ให้เช็คสถานะย้อนหลังได้ตลอดเวลา

#### ◆ Enterprise SaaS Production Readiness

พร้อมรองรับ Multi-Tenant Isolation, ปลอดภัยมาตรฐานสากล และทำงานแบบ Zero-Manual Review 24/7

##### PRODUCTION GRADE